

Controls, Frameworks & the Defense Toolkit

Control categories

Type	Purpose	Example
Preventive	Stop it happening	Firewall, patch, policy
Detective	Find it happening	IDS, logging, AV
Corrective	Recover / undo damage	Backups, IR, patching
Directive	Guide behavior	Policy, training
Deterrent	Discourage attacks	Warning banners, cameras
Compensating	Alternative control when ideal is impossible	MFA token in lieu of hardware key

Control implementation classes

- Physical – locks, cameras, cages
- Technical – software, hardware, cryptographic
- Administrative – policy, procedure, training

Strong security layers them: policy + training (admin) + MFA (technical) + locked server room (physical).

The frameworks that matter

- NIST CSF 2.0 – Govern, Identify, Protect, Detect, Respond, Recover
- CIS Controls v8 – 18 prioritized safeguards (asset inventory, continuous vuln management, secure config, etc.)
- ISO 27001 – certifiable ISMS standard, 93+ Annex A controls
- NIST 800-53 – deep catalog of controls for US federal systems

Defense in depth

Chart of layered controls:

Users	-> training, policies, hardened browsers
Perimeter	-> firewalls, WAF, IDS/IPS, VPN/ZTNA
Network	-> segmentation, micro-segmentation, monitoring
Endpoints	-> EDR, application allow-listing, full-disk encryption
App/Data	-> secure coding, encryption, DLP, RBAC
Physical	-> access control, cameras, air-gap

Assume any single layer fails. Design so that one failure does not become total compromise.

[← Ethics, Laws & the Security ...](#)

Module complete ✓